ISA/IEC 62443-3-3 / 4-2 • SL-3 TESTING CHEAT SHEET

Schneider Electric / Square D PowerLogic Model 98A Digital Temperature Controller (legacy RS-485 Modbus / SY-MAX) · Component type: **Embedded Device (EDR) - legacy transformer-winding temperature controller (obsolete)** · Target SL = SL 3

Where to work	Native config is at the **front-panel keypad + digital display** (winding/ambient setpoints, FAN/ALARM/TRIP relay setpoints, RS-485 **address** + baud, protocol select Modbus/SY-MAX) - confirm the exact key sequence + any **programming passcode/lock** against **Square D Instruction Bulletin 43500-054-26A** on the unit. Remote data is read/written over **RS-485** (**Modbus RTU** or **SY/MAX**) by a SCADA master, typically through a **serial-to-Ethernet / Modbus-TCP gateway**. There is no web/IP interface on the device itself.
Ports / paths	**RS-485** 2-wire serial (block-connector terminals) - **Modbus RTU** + **SY/MAX** protocol; **front-panel keypad/display**; output relays **FAN / ALARM / TRIP** (status LEDs); **RTD** winding-temperature probe inputs; **120 VAC** supply (**TB1 13&14**; fan relays **TB2 3&4**). **No native Ethernet / web / IP** - network exposure exists only via an external **serial-to-Ethernet / Modbus-TCP gateway (TCP 502)**. Obsolete/discontinued.
Notes / lifecycle	LEGACY / OBSOLETE Square D device (part e.g. **M98A-P-4-M**; replaces Lifeguard 85A / Model 98). No user accounts, no cryptography, no firmware update / secure boot - it **cannot meet SL-3 natively**, so most rows resolve to N-A-at-device + compensating controls and a **lifecycle/replacement plan**. Two safety anchors dominate: (1) the over-temperature protection (TRIP/FAN on RTD) must be **independent of the comms link**; (2) **physical** control of the transformer cabinet is the primary control.
How to read	Default read-only (record setpoints/relay-setpoints/address from the keypad; read-only Modbus register reads via the master/gateway; physical inspection). Each row = native step-by-step + command-level external-tool validation + pass. Write/exploit tools = isolated bench + written authorization (a mis-set temp controller can disable transformer thermal protection). Many rows are honestly N-A-at-device / Compensating.

Project / config capture & evidence handling - capture the device backup + config export

Do this BEFORE working the checklist - screenshots and walking the config screens are not enough on their own. Capture the device's own backup / project export so nothing is missed:
1. Pull the native backup / project + full config export first (read-only, before anything): a written parameter/setpoint list + **photographs of each front-panel screen** (there is no software project file), the RS-485 Modbus/SY-MAX comms settings, the FAN/ALARM/TRIP setpoints, and the model/firmware from the nameplate.
2. Export the security-relevant settings: user accounts / roles / password policy, comms / port / protocol enable-disable, and any certificate / key / CIP-Security settings - as files and screenshots.
3. Collect firmware & logs: firmware / boot revision, and the event / audit / diagnostic logs and fault / alarm buffers (exports) where the device provides them.
4. Capture the device identity: nameplate (catalog + serial), firmware / hardware rev, installed modules / option cards, and slot / network address - **photograph** the device, faceplate / HIM and panel labels.
5. Name + protect (keep everything): `<site>_<zone>_<assetTag>_<vendor>_<model>_<fwRev>_<YYYYMMDD-HHMM>_<initials>` with the native project / backup extension + the exports; SHA-256 hash the backup; store **only** on the encrypted evidence share; the backup may hold credentials / keys - **never** email it in cleartext and follow the project retention / classification policy. Do not save device passwords in tool profiles.
6. Then analyze offsite against the product-specific checklist, the product manuals, vendor research and experience; fill in the tool and auto-generate the report - and remember the manual fields the tool can't auto-write: the **executive-summary narrative**, the **overall assurance level + justification**, and the **punch-list**.

FR 1 — Identification & Authentication Control (IAC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 1.1	Human user identification & auth	The device has **no user accounts**. Local changes are made at the **front-panel keypad** - if the unit supports a **programming passcode / keypad lock** (confirm against IB 43500-054-26A), enable it so setpoint/relay changes require it; the **RS-485 Modbus/SY-MAX** interface has **no authentication**. Compensate with physical cabinet access control + restricting the serial master. **Test:** at the keypad, attempt to enter programming/change a setpoint -> passcode required (if supported); confirm no anonymous serial write path is reachable outside the controlled loop. **Ext. tools:** Physical keypad check (passcode/lock per bulletin); confirm only the authorized master polls the RS-485 loop.	Keypad lock enabled (if supported) + physical + serial-master control; unauthenticated Modbus compensated.	EDR - no device auth; compensating.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 1.2	Device & software-process I&A	Modbus/SY-MAX are **unauthenticated**; the device is identified only by its **Modbus slave address / SY-MAX drop**. Bind identity by a single known master + segmentation; document the address and the one authorized master. **Test:** from a non-authorized master, poll the device -> blocked by loop control/segmentation. **Ext. tools:** `modpoll -m rtu -a -b -1 /dev/ttyUSB0` (read-only, authorized) or via the gateway `modpoll -m tcp -a` ; confirm slave address.	Device identified by slave address; single authorized master; unauthenticated protocol compensated by segmentation.	No device auth - Compensating.
SR/CR 1.3	Account management	No device accounts to manage; manage the **keypad passcode** (if any) as a controlled shared secret and the access list of who may reach the RS-485 master / gateway. Keep a controlled record of the setpoint/relay configuration. **Ext. tools:** Passcode custody record; master/gateway access review; setpoint config record.	Keypad secret + master access controlled; config recorded.	Adapter/device: no accounts.
SR/CR 1.4	Identifier management	Confirm a **unique Modbus slave address / SY-MAX drop** on the RS-485 loop (no duplicates), and a unique tag/location for the controller and each transformer it protects. **Ext. tools:** Keypad (address); `modpoll` scan of the loop for address collisions; asset register.	Unique serial address + asset identity; no reuse on the loop.	
SR/CR 1.5	Authenticator management	The device stores **no credentials**; the only authenticator is the optional **keypad passcode** - if present, set it to a non-default value and control it; if not present, document the gap and compensate physically. **Ext. tools:** Keypad (passcode set/non-default per bulletin); document gap if unsupported.	Keypad passcode non-default (if supported); gap documented + physically compensated.	Legacy - limited/none.
SR 1.6	Wireless access management	**N/A.** Wired serial device with no wireless interface. **Ext. tools:** Confirm no wireless.	N/A - justification recorded (wired device).	N/A
SR/CR 1.7	Strength of password-based authentication	Confirm the password-strength policy (length/complexity/lifetime) meets SL-3. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.5** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of password-based authentication verified individually.	
SR/CR 1.8	Public key infrastructure (PKI) certificates	**N/A at device.** No PKI/TLS/crypto on a legacy RS-485 controller. Record N/A; integrity/confidentiality are provided by segmentation and (if bridged) TLS terminated at a modern gateway/SCADA layer. **Ext. tools:** Confirm no device certificate/crypto; Wireshark/serial capture (cleartext).	N/A device PKI; compensating segmentation/upstream TLS.	N/A.
SR/CR 1.9	Strength of public key-based authentication	Confirm public-key authentication uses strong, current keys/algorithms. **Steps:** for this product this is assessed with the same evidence as **SR/CR 1.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Strength of public key-based authentication verified individually.	
SR/CR 1.10	Authenticator feedback	If the keypad passcode is supported, confirm entry does not display the secret in clear on the panel; otherwise N/A. **Ext. tools:** Visual keypad check (per bulletin).	Passcode obscured if supported; else N/A.	N/A/verify.
SR/CR 1.11	Unsuccessful login attempts	No serial login and (typically) no keypad lockout counter on a legacy unit. Remove exposure with physical control + serial segmentation; monitor for abnormal serial writes at the master/IDS. **Ext. tools:** Physical control; serial/Modbus IDS at the master/gateway.	No native lockout; physical + segmentation + monitoring compensate.	Legacy limitation.
SR/CR 1.12	System use notification	**N/A at device.** No display banner capability; apply an approved-use placard on the transformer control cabinet (compensating). **Ext. tools:** Physical placard/label review.	Use notice via cabinet placard (compensating).	Compensating.
SR 1.13	Access via untrusted networks	The RS-485 loop is local; there is **no direct network**. If a **serial-to-Ethernet / Modbus-TCP gateway** exposes it, segment and firewall that gateway (TCP 502) so no untrusted network can reach the loop; no remote write without brokered access. **Test:** from an untrusted VLAN, reach the gateway 502 / the device -> must fail. **Ext. tools:** `nmap -Pn -p 502` from the untrusted side (expect filtered); firewall + gateway review; confirm no rogue serial-to-Ethernet bridge on the loop.	RS-485 loop + any gateway unreachable from untrusted networks; brokered access only.	

FR 2 — Use Control (UC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 2.1	Authorization enforcement	No role model. The only authorization is the optional **keypad lock** (gating setpoint/relay-setpoint changes) and **read-only vs read/write Modbus**. Identify which registers are writable (setpoints, relay setpoints, alarm reset) and restrict writes at the master/gateway to authorized functions only. **Test:** attempt a Modbus write to a temperature/relay setpoint from an unauthorized path -> blocked by master/gateway ACL; confirm read-only points cannot be written. **Ext. tools:** Modbus map review; `modpoll` read-back to confirm write scope (authorized, isolated); gateway/master write ACL.	Setpoint changes gated by keypad lock + restricted-write master; read-only points enforced.	No device roles - Compensating.
SR/CR 2.2	Wireless Use Control	**N/A.** No wireless interface on this device; wireless access is managed at the network layer.	N/A - justification recorded (not assessed as a control).	N/A
SR 2.3	Use control for portable/mobile devices	Control any laptop/handheld + USB-RS485 adapter used to reach the loop; only authorized personnel connect to the RS-485 terminals or the gateway; physical port control. **Ext. tools:** Host/media control on the service laptop; physical inspection of the RS-485 terminals.	Serial-service media + terminal access controlled.	
SR/EDR 2.4	Mobile code	**N/A.** Fixed-function firmware; no general-purpose or downloadable code executes on the controller. **Ext. tools:** Confirm fixed-function device (no code load path).	N/A - no mobile code path (fixed firmware).	EDR-specific / N/A.
SR/CR 2.5	Session lock	Confirm the keypad returns to the temperature display after inactivity (re-entry of programming required); no serial session to lock. **Ext. tools:** Keypad inactivity behavior (per bulletin).	Keypad reverts to display on inactivity (if supported).	Verify.
SR/CR 2.6	Remote session termination	RS-485 is a single-master multidrop loop - confirm one authorized master and that the device does not accept conflicting concurrent writes; the loop bounds concurrency. **Ext. tools:** Loop topology review (single master); serial capture (one master polling).	Single authorized master; concurrency bounded by the loop.	
SR/CR 2.7	Concurrent session control	Confirm concurrent sessions are bounded/limited and monitored. **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Concurrent session control verified individually.	
SR/CR 2.8	Auditable events	The device has **no native logging**. Capture the security/safety-relevant events off-device: the **ALARM/TRIP relay** states and winding temperatures at the SCADA/historian, and setpoint-change events at the Modbus master; a serial/Modbus-aware IDS on the loop/gateway records writes. Attribution is at the master/keypad-access layer. **Ext. tools:** SCADA/historian (alarm/trip/temp points); Modbus master change log; serial/Modbus IDS at the gateway + SIEM.	Alarms/trips/temps + writes captured off-device; attribution at master/physical layer.	No native log - Compensating.
SR/CR 2.9	Audit storage capacity	Because logging is off-device, confirm the SCADA/historian/SIEM are sized/retained and alert on collection or **comms-loss** failure so a silent loss of the temperature signal is detected. **Ext. tools:** SCADA/SIEM retention + comms-loss alarm review.	Off-device logs sized/retained; comms-loss/audit-failure alerting defined.	Compensating.
SR/CR 2.10	Response to audit processing failures	Confirm a defined response to audit-processing/forwarding failures (alerting; no silent loss). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.9** above (shared steps); confirm this requirement individually and adjudicate it separately.	Response to audit processing failures verified individually.	
SR/CR 2.11	Timestamps	The controller has **no RTC**; events are timestamped by the SCADA/master on receipt. Confirm the master/historian is time-synced (NTP) so temperature/alarm events correlate. **Ext. tools:** Master/historian NTP check (`w32tm /query /status` / `ntpq -p`).	Correlatable time via the synced master/historian (device has no clock).	Time off-device.
SR/CR 2.12	Non-repudiation	Confirm actions are attributable to a specific user (non-repudiation). **Steps:** for this product this is assessed with the same evidence as **SR/CR 2.8** above (shared steps); confirm this requirement individually and adjudicate it separately.	Non-repudiation verified individually.	
EDR 2.13	Physical diagnostic & test interfaces	**Primary control.** The **front-panel keypad**, the **RS-485 terminal block**, and the relay/RTD wiring are the interfaces - keep the transformer control cabinet **locked and sealed**, control access to the keypad and terminals, and blank/secure any unused programming access. **Ext. tools:** Physical inspection (cabinet lock/seal, keypad access, terminal covers).	Physical/diagnostic interfaces controlled; cabinet locked/sealed.	EDR-specific - primary.

FR 3 — System Integrity (SI)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 3.1	Communication integrity	Modbus RTU / SY-MAX over RS-485 are **unauthenticated cleartext** with no crypto option - integrity/confidentiality come from **containment**: keep the RS-485 loop physically secured and, if bridged, contain the Modbus-TCP gateway in a segmented zone; no cleartext control leaves the controlled area. **Test:** confirm the serial loop is physically contained and any gateway traffic stays in-zone. **Ext. tools:** Serial capture / `modpoll` (cleartext confirmation); Wireshark on the gateway (`modbus`, in-zone only); firewall review.	Serial/gateway comms contained/segmented; no uncontrolled cleartext (no native crypto).	No crypto - Compensating.
SR/EDR 3.2	Protection from malicious code (component)	**N/A / limited.** Fixed-function firmware with no field code-load path; there is no documented signed-firmware mechanism. Record N/A for signing; compensate with physical control, provenance of any spare/replacement unit, and segmentation. **Ext. tools:** Confirm no code-load path; spare-unit provenance.	No code-load path; signing N/A; compensating physical/provenance controls.	EDR-specific / N/A.
SR/CR 3.3	Security functionality verification	After any change re-verify: keypad lock (if any), Modbus/SY-MAX address + protocol select, writable-register restriction at the master, gateway segmentation, and relay setpoints, against the recorded baseline; read the setpoints back via Modbus. **Ext. tools:** Keypad review + `modpoll` read-back vs baseline; `nmap -p 502 .`	Security/safety settings match the recorded baseline after change.	
SR/CR 3.4	Software & information integrity	The "config" is the winding/relay **setpoints** + Modbus **address/protocol** - record them as a baseline (photograph the keypad values / export via Modbus) and detect drift by periodic read-back; unauthorized setpoint change is the key integrity risk (it can defeat thermal protection). **Ext. tools:** Baseline setpoint sheet; periodic `modpoll` read-back compare for drift.	Setpoint/config baseline recorded; drift detected by read-back.	
SR/CR 3.5	Input validation	Confirm the controller tolerates malformed **Modbus/SY-MAX** frames without faulting or dropping temperature protection. **ISOLATED bench only:** fuzz the serial interface on a spare unit and watch the relays/display (a fault here could disable transformer cooling/trip). **Ext. tools:** Serial/Modbus fuzzer (`boofuzz` over RS-485) on a bench unit; watch FAN/ALARM/TRIP relays + display.	No fault or loss of protection on malformed serial input.	Do NOT fuzz an in-service controller.
SR/CR 3.6	Deterministic output	**Safety-critical row.** Confirm the FAN/ALARM/**TRIP** relays assume a defined safe state and that the over-temperature protection acts on the **RTD locally, independent of comms**: verify fail-safe on power loss, on **RTD open/short**, and on comm loss (device still trips/cools on real over-temp regardless of the Modbus link). **Test:** ISOLATED: simulate over-temp / RTD fault / comm loss -> relays go to the defined safe state; protection does not depend on comms. **Ext. tools:** Bench RTD simulator; relay-state observation; confirm fail-safe per the bulletin.	Relays fail to a defined safe state; over-temp protection is comms-independent.	Safety-critical.
SR/CR 3.7	Error handling	Confirm RTD open/short and sensor-fault detection drive a defined alarm/indication rather than a silent failure; graceful handling with no unsafe state. **Ext. tools:** Bench RTD open/short test; confirm fault alarm/indication (per bulletin).	Sensor/RTD faults produce a defined alarm; no silent unsafe failure.	
SR/CR 3.8	Session integrity	**N/A.** No authenticated/encrypted session on a legacy serial device; integrity by containment. Record N/A + compensating segmentation. **Ext. tools:** Confirm no session security; segmentation review.	N/A at device; compensating segmentation recorded.	N/A.
SR/CR 3.9	Protection of audit information	Since audit is off-device, protect the SCADA/historian/IDS/SIEM store and restrict who can read/clear it. **Ext. tools:** SCADA/SIEM access review.	Off-device audit records protected from unauthorized access.	
EDR 3.10	Support for updates	**N/A / limited.** Legacy/obsolete device - typically **no field firmware update** path (factory-only if any). Record N/A; manage risk via physical control, segmentation, monitoring, and a **replacement/obsolescence plan**. **Ext. tools:** Confirm no field-update path; record obsolescence/replacement plan.	No field update path (obsolete); compensating controls + replacement plan recorded.	EDR-specific / N/A.
EDR 3.11	Physical tamper resistance/detection	Keep the controller in a **locked/sealed transformer control cabinet**; seal the keypad/terminal access; tamper is deterred/detected physically (the primary control for this device). **Ext. tools:** Physical inspection (cabinet lock/seal, keypad/terminal covers, tamper evidence).	Cabinet locked/sealed; physical tamper deterrence/detection in place.	EDR-specific - primary.

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
EDR 3.12	Provisioning product-supplier roots of trust	**N/A.** No signed-firmware supplier root of trust on this legacy device. Record N/A; compensate with spare-unit provenance, physical control, and the replacement plan. **Ext. tools:** Confirm no RoT; provenance process for spares.	No supplier RoT (legacy); compensating controls recorded.	N/A.
EDR 3.13	Provisioning asset-owner roots of trust	**N/A.** No asset-owner certificate provisioning (no PKI). Record N/A; asset-owner trust enforced at the network/gateway + physical layer. **Ext. tools:** Confirm no cert provisioning; segmentation review.	No asset-owner RoT (legacy); compensating controls recorded.	N/A.
EDR 3.14	Integrity of the boot process	**N/A.** No verified/secure boot on this legacy device. Record N/A; mitigate via physical control, segmentation, monitoring, and the replacement plan. **Ext. tools:** Confirm no secure-boot capability.	No verified boot (legacy); compensating controls recorded.	N/A.

FR 4 — Data Confidentiality (DC)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 4.1	Information confidentiality	Confirm information confidentiality — sensitive data is protected in transit and at rest. **Steps:** for this product this is assessed with the same evidence as **SR/CR 3.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Information confidentiality verified individually.	
SR/CR 4.2	Information persistence	On decommission/repurpose, reset the setpoints/relay-setpoints and Modbus address to defaults so site-specific configuration is not left on a surplus unit (the device holds little sensitive data - setpoints + address). **Ext. tools:** Keypad reset to defaults; confirm no site config remains.	Setpoints/address cleared on decommission or reuse.	
SR/CR 4.3	Use of cryptography	**N/A.** No cryptography on the device. Rely on segmentation; where confidentiality across a bridged link is required, terminate it at a modern gateway/SCADA layer. **Ext. tools:** Confirm no device crypto; segmentation/gateway review.	No device crypto - compensating segmentation.	N/A.

FR 5 — Restricted Data Flow (RDF)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 5.1	Network segmentation	Primary control. Keep the RS-485 loop in a controlled area; if bridged, place the **Modbus-TCP gateway** in a segmented OT zone behind a firewall so only the authorized master polls the device; no flat convergence with IT; the temperature loop is not routable from untrusted networks. **Ext. tools:** `nmap -p 502` per zone; firewall/gateway rule review; loop topology review.	Serial loop + gateway in a controlled/segmented zone; only the authorized master reaches the device.	
SR 5.2	Zone boundary protection	Confirm zone-boundary protection — only required flows cross the boundary (system SR / network device). **Steps:** for this product this is assessed with the same evidence as **SR/CR 5.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Zone boundary protection verified individually.	
SR 5.3	General-purpose person-to-person comms restrictions	**N/A.** Single-purpose temperature controller with no person-to-person messaging. **Ext. tools:** Confirm no such services.	N/A - justification recorded.	N/A
SR 5.4	Application partitioning	**N/A.** Single-function device; nothing to partition. **Ext. tools:** Confirm single-function device.	N/A - justification recorded.	N/A

FR 6 — Timely Response to Events (TRE)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 6.1	Audit log accessibility	The device has no native log - monitor off-device: confirm the SCADA/historian captures winding temperature + **ALARM/TRIP** and alarms on **comms loss** (a dead controller = loss of thermal-protection visibility), and a serial/Modbus-aware IDS watches the loop/gateway for anomalous writes; forward to the SIEM. **Ext. tools:** SCADA/historian (temp/alarm/trip + comms-loss alarm); serial/Modbus IDS at the gateway; SIEM.	Temperature/alarm/trip + comms-loss monitored off-device in near-real-time.	No native log - Compensating.
SR/CR 6.2	Continuous monitoring	Confirm continuous monitoring — events forwarded to and monitored by a SIEM/OT-IDS in near-real-time. **Steps:** for this product this is assessed with the same evidence as **SR/CR 6.1** above (shared steps); confirm this requirement individually and adjudicate it separately.	Continuous monitoring verified individually.	

FR 7 — Resource Availability (RA)

Req (3-3 / 4-2)	Requirement	Where & how to verify (native steps + Ext. tools)	Pass criteria / evidence	Notes / lifecycle
SR/CR 7.1	Denial-of-service protection	Confirm the **protection function is independent of comms**: a serial/gateway flood may disrupt SCADA polling but must NOT stop the local RTD-based FAN/TRIP action. Verify local control continues under a serial storm; rate-limit/segment the gateway. **Ext. tools:** ISOLATED bench: serial/Modbus storm (or `hping3 --flood -p 502` at the gateway); confirm local FAN/TRIP still act on RTD.	Local thermal protection continues under comms DoS; gateway rate-limited/segmented.	Safety-relevant.
SR/CR 7.2	Resource management	Confirm the controller keeps measuring/controlling under serial load and that a single service (comms) cannot starve the protection logic. **Ext. tools:** Bench load test; observe measurement/relay continuity.	Protection resources bounded/independent; no comms-induced loss of control.	
SR/CR 7.3	Control system backup	Record the full **setpoint / relay-setpoint / address / protocol** configuration (parameter sheet) so a replacement unit can be reconfigured; hold a **spare** (device is obsolete) and test its configuration on the bench. **Ext. tools:** Parameter/config sheet; spare-unit config + bench validation.	Config recorded for rebuild; spare held + validated (obsolete-part plan).	
SR/CR 7.4	Control system recovery & reconstitution	Confirm recovery/reconstitution — a restore to a known-good state is tested. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.3** above (shared steps); confirm this requirement individually and adjudicate it separately.	Control system recovery & reconstitution verified individually.	
SR 7.5	Emergency Power	**N/A.** Emergency/backup power is provided at the facility/UPS level, not the device; confirm the device retains its security state across a power transfer.	N/A - justification recorded (not assessed as a control).	N/A
SR/CR 7.6	Network & security configuration settings	Harden the little there is: enable the keypad lock (if supported), use a single protocol (Modbus **or** SY-MAX, disable the unused one if selectable), set a non-default Modbus address, restrict writes at the master/gateway, and physically secure the unit. **Ext. tools:** Keypad review (lock/protocol/address); master/gateway write ACL; `nmap -p 502 .`	Least functionality: one protocol, keypad lock, non-default address, restricted writes.	
SR/CR 7.7	Least functionality	Confirm least functionality — unused services/ports/protocols are disabled. **Steps:** for this product this is assessed with the same evidence as **SR/CR 7.6** above (shared steps); confirm this requirement individually and adjudicate it separately.	Least functionality verified individually.	
SR/CR 7.8	Component inventory	Inventory the controller (Model 98A, part e.g. M98A-P-4-M, firmware rev if shown, protocol/address, transformer served) and flag it as **OBSOLETE** for the lifecycle/replacement program; track any Schneider/Square D or CISA advisories. **Ext. tools:** Keypad/nameplate (model/part/rev); asset register (mark obsolete); Schneider/CISA advisory check.	Accurate inventory incl. obsolescence flag; advisories tracked; replacement planned.	

External Test Tools — how to use

Tool / method	Verifies	How to use — steps / example	Constraints
Front-panel keypad + display / IB 43500-054-26A	Native config & keypad-lock review (most FRs)	Read/record winding & relay setpoints, RS-485 address/baud, protocol select, and any programming passcode; confirm the exact key sequence + lock behavior against Square D Instruction Bulletin 43500-054-26A on the unit.	Read-only; authorized; record baseline.
modpoll / mbpoll (RS-485 or via gateway)	Read-back, address & write-scope (1.2, 2.1, 3.3, 3.4)	`modpoll -m rtu -a -b -1 /dev/ttyUSB0` or `modpoll -m tcp -a` ; read setpoints/temps; confirm which registers are writable (authorized/isolated).	Read-only on production; writes isolated.
Serial protocol analyzer / Wireshark	Comms integrity & containment (1.2, 3.1)	Capture the RS-485 Modbus/SY-MAX (USB-RS485 tap) or `modbus` at the gateway; confirm cleartext stays within the controlled loop/zone; inspect writes.	Passive; tap/SPAN only.
nmap	Gateway exposure & segmentation (1.13, 5.x, 7.x)	`nmap -Pn -p 502` per zone; confirm the Modbus-TCP gateway is reachable only from the authorized segment; confirm no rogue serial-to-Ethernet bridge.	Read-only; authorized.
Serial/Modbus fuzzer (isolated)	Input validation (3.5)	`boofuzz` Modbus/SY-MAX over RS-485 to a BENCH unit; watch FAN/ALARM/TRIP relays + display for faulting.	ISOLATED bench; written authorization.
RTD simulator + relay observation (bench)	Deterministic/fail-safe output & error handling (3.6, 3.7)	Inject over-temp / RTD open-short / comm loss on a bench unit; confirm relays go to the defined safe state and protection is comms-independent (per the bulletin).	ISOLATED bench; safety verification.
SCADA/historian + serial/Modbus OT IDS	Monitoring & audit off-device (2.8, 6.x)	Confirm temperature/ALARM/TRIP + comms-loss are captured/alarmed at the SCADA and that an IDS watches the loop/gateway for anomalous writes; forward to the SIEM.	Passive; coordinate with SOC.
Schneider/Square D + CISA advisories	Vuln tracking & lifecycle (7.8)	Track any advisories for the Model 98/98A; record the device as obsolete and drive the replacement plan.	Reference.

Controlled - Project Use · Independent Assurance Services · ISA/IEC 62443-3-3 / 4-2 · Product-specific companion to the 62443 assessment tool; confirm exact menu paths / CLI against the deployed firmware and the project hardening baseline. ISOLATED tools run only in a representative/lab environment with written authorization.